

GRC + Incident + Pentesting

4/24/26

8:56 PM

1. Core Mindset (Foundation)

- **Goal:** Manage risk so attacks are not worth it (cost > reward).
- **Think like an attacker:** balance **effort, cost, reward**.
- **Security exists to support business**, not block it.

CIA Triad (always baseline)

- **Confidentiality** – prevent unauthorized access
- **Integrity** – prevent unauthorized changes
- **Availability** – ensure access when needed

2. Risk Management (Core Engine)

Risk Formula

- **Risk = Impact × Likelihood**
- **Residual Risk:** what remains after controls → compare to **risk appetite**

Impact Categories (always assess together)

1. Safety (highest)
2. Financial
3. Reputational
4. Regulatory/Legal

Likelihood (based on controls)

- No controls → **Almost Certain**
- Partial → **Probable**
- Strong/layered → **Possible** (never zero)

Defense in Depth (3 Layers)

1. **Endpoints / Entry** – MFA, patching
2. **Network Boundaries** – firewalls, segmentation
3. **End-to-End** – encryption, monitoring

Attack Surface Drivers

- Size
- Exposure (internet-facing)
- Complexity / distribution

3. Business Impact Analysis (BIA)

Purpose

- Answer: **“What happens if this breaks?”**

Key Metrics

- **RTO:** max downtime allowed
- **RPO:** max data loss allowed

Approach

- Map: **Infrastructure** → **Apps** → **Business Services**
- Prioritize **critical business functions**
- Consider **peak vs off-peak impact**

Key Insight

- Supporting systems must often have **stricter RTO/RPO** than the business service.

4. Governance (Structure & Control)

Governance vs Management

- **Governance:** direction, oversight (board/CISO)
- **Management:** execution (IT/security teams)

Core Components

- **Policies** → what/why
 - **Standards** → specific requirements
 - **Procedures** → step-by-step
 - **Processes** → end-to-end workflows
- 👉 If these don't align → governance fails.

Scope & SoA

- **Scope:** what systems/data are included
- **SoA (Statement of Applicability):**
 - Which controls apply (e.g., ISO 27001)
 - Why + implementation status

Controls (3 Types)

- **Preventive:** stop attacks (MFA)
- **Detective:** find attacks (logs)
- **Corrective:** fix issues (backups)

Key Governance Concepts

- **Separation of Duties:** no single person controls everything
- **Exception Handling:** controlled policy bypass
- **Maturity Models (CMMI):** improve over time

Compliance Types

- **Statutory:** laws (GDPR, HIPAA)
- **Regulatory:** industry (PCI-DSS)
- **Contractual:** agreements
- **Voluntary:** ISO, certifications

Operating Model

- Work across:
 - HR (onboarding/offboarding)
 - Legal (compliance)
 - Procurement (vendors)

👉 You act as the **bridge between departments**

5. Risk Across Lifecycle

Phases

1. **Discovery:** identify inherent risk
2. **Design:** architecture risks
3. **Build/Test:** validation, pentesting
4. **Deploy:** readiness + residual risk
5. **Operate:** monitoring, incidents
6. **Decommission:** secure disposal

Assessment Approaches

- **Top-down:** business impact
- **Bottom-up:** technical controls
- ☒ Best = **combine both**

Key Improvement Concepts

- Avoid bias/overconfidence
- Move unknown risks → known (**Johari Window**)
- Always document assumptions

6. Incident Management (CISM Focus)

Goal

Minimize damage + restore operations + learn.

Lifecycle

1. **Preparation**
2. **Detection**
3. **Triage**
4. **Containment**
5. **Eradication**
6. **Recovery**
7. **Lessons Learned**

Planning (IRP, BCP, DRP)

- **IRP:** how to respond to incidents
- **BCP:** keep business running
- **DRP:** restore systems

👉 Must be **aligned with BIA (RTO/RPO)**

Containment

- Short-term: isolate quickly
- Long-term: stabilize environment

Eradication

- Remove root cause (malware, access)
- Patch or rebuild systems

Investigation

- Build **timeline**
- Identify **root cause + scope**
- Classify severity

Evidence Handling

- Maintain **chain of custody**
- Follow **order of volatility**
- Work on **copies only**
- Verify with **hashing**

Documentation

- Record everything (actions, decisions, timelines)
- Critical for legal + improvement

Post-Incident

- Focus on **improvement, not blame**
- Update:
 - Controls
 - Plans
 - Training

7. Business Continuity & Recovery

Backups (3-2-1 Rule)

- 3 copies
- 2 media types
- 1 offsite

👉 Add:

- Encryption
- Immutability (ransomware defense)
- Regular restore testing

Recovery Sites

- **Hot:** instant, expensive
- **Warm:** moderate setup
- **Cold:** slow, cheap

👉 Choose based on **RTO/RPO vs cost**

8. Pentesting (Planning → Recon)

Core Idea

- Plan first → avoid legal risk + wasted effort

Key Documents

- **NDA:** protect data
- **MSA:** overall contract
- **SOW:** specific engagement
- **RoE:** what's allowed
- **Communication Plan:** escalation paths

👉 These prevent **legal issues + scope creep**

Project Management

- Define:
 - Scope
 - Timeline
 - Deliverables
- Take structured notes (CherryTree, OneNote)

Passive Recon (OSINT)

Goal

- Gather intel **without touching target**

What to Find

- Domains, IPs, services
- Tech stack
- Employees/emails
- Leaked credentials
- Public files/metadata

Key Tools/Methods

- **Job postings** → tech stack
- **Shodan** → exposed services
- **Hunter.io** → emails
- **DeHashed** → breaches
- **Google Dorks** → exposed files
- **theHarvester / Amass** → domains
- **MetaGooFil** → document metadata

Why It Matters

- Maps real attack surface
- Finds easy wins (misconfigs, leaks)
- Enables targeted attacks
- Keeps engagement stealthy

9. Final Big Picture (How Everything Connects)

- **Governance** defines rules
- **Risk Management** prioritizes what matters
- **BIA** defines impact (RTO/RPO)
- **Controls** reduce likelihood
- **Incident Management** handles failures
- **BCP/DRP** ensure resilience
- **Pentesting** tests defenses